

UNIVERSIDAD DE LAS PALMAS DE GRAN CANARIA
Escuela de Ingeniería Informática

Práctica 8:
Amenazas a la Seguridad Digital

Asignatura: Seguridad de la Información

Curso: 4º de Grado en Ingeniería Informática

Autor:

Nicolás Rey Alonso

`nicolas.rey101@alu.ulpgc.es`

Fecha: Abril 2026

Índice general

1. Introducción	5
1.1. Objetivos de la práctica	5
1.2. Fundamentos teóricos	5
1.3. Enunciado de la práctica	6
2. phishing, estafas a través de la red	7
2.1. Breve descripción de la amenaza: (más de 100 palabras)	7
2.2. Fecha de la noticia:	7
2.3. Título de la noticia:	7
2.4. Enlace a la noticia:	8
2.5. Medio:	8
2.6. Enlace al medio:	8
2.7. Nacionalidad del medio:	8
2.8. Idioma de la noticia:	8
2.9. Pequeña imagen de la noticia:	8
2.10. Breve resumen de la noticia: (más de 100 palabras)	9
2.11. Relación con la amenaza:	9
2.12. ¿Existe CVE o CWE asociado a la noticia?	9
2.13. Impacto ocasionado por la amenaza en esta noticia: (más de 100 palabras)	9
3. Malware difundido en redes sociales	11
3.1. Breve descripción de la amenaza: (más de 100 palabras)	11
3.2. Fecha de la noticia:	11

3.3. Título de la noticia:	11
3.4. Enlace a la noticia:	12
3.5. Medio:	12
3.6. Enlace al medio:	12
3.7. Nacionalidad del medio:	12
3.8. Idioma de la noticia:	12
3.9. Pequeña imagen de la noticia:	12
3.10. Breve resumen de la noticia: (más de 100 palabras)	13
3.11. Relación con la amenaza:	13
3.12. ¿Existe CVE o CWE asociado a la noticia?	13
3.13. Impacto ocasionado por la amenaza en esta noticia: (más de 100 palabras)	13
4. Ataques de ransomware contra corporaciones y gobiernos	15
4.1. Breve descripción de la amenaza: (más de 100 palabras)	15
4.2. Fecha de la noticia:	15
4.3. Título de la noticia:	15
4.4. Enlace a la noticia:	16
4.5. Medio:	16
4.6. Enlace al medio:	16
4.7. Nacionalidad del medio:	16
4.8. Idioma de la noticia:	16
4.9. Pequeña imagen de la noticia:	16
4.10. Breve resumen de la noticia: (más de 100 palabras)	17
4.11. Relación con la amenaza:	17
4.12. ¿Existe CVE o CWE asociado a la noticia?	17
4.13. Impacto ocasionado por la amenaza en esta noticia: (más de 100 palabras)	17
5. Botnets, ordenadores zombies	19
5.1. Breve descripción de la amenaza: (más de 100 palabras)	19
5.2. Fecha de la noticia:	19

5.3. Título de la noticia:	19
5.4. Enlace a la noticia:	20
5.5. Medio:	20
5.6. Enlace al medio:	20
5.7. Nacionalidad del medio:	20
5.8. Idioma de la noticia:	20
5.9. Pequeña imagen de la noticia:	20
5.10. Breve resumen de la noticia: (más de 100 palabras)	21
5.11. Relación con la amenaza:	21
5.12. ¿Existe CVE o CWE asociado a la noticia?	21
5.13. Impacto ocasionado por la amenaza en esta noticia: (más de 100 palabras) . . .	21
6. Malware en dispositivos móviles	23
6.1. Breve descripción de la amenaza: (más de 100 palabras)	23
6.2. Fecha de la noticia:	23
6.3. Título de la noticia:	23
6.4. Enlace a la noticia:	24
6.5. Medio:	24
6.6. Enlace al medio:	24
6.7. Nacionalidad del medio:	24
6.8. Idioma de la noticia:	24
6.9. Pequeña imagen de la noticia:	24
6.10. Breve resumen de la noticia: (más de 100 palabras)	25
6.11. Relación con la amenaza:	25
6.12. ¿Existe CVE o CWE asociado a la noticia?	25
6.13. Impacto ocasionado por la amenaza en esta noticia: (más de 100 palabras) . . .	25
7. Inyección de código SQL	27
7.1. Breve descripción de la amenaza: (más de 100 palabras)	27
7.2. Fecha de la noticia:	27

7.3. Título de la noticia:	27
7.4. Enlace a la noticia:	28
7.5. Medio:	28
7.6. Enlace al medio:	28
7.7. Nacionalidad del medio:	28
7.8. Idioma de la noticia:	28
7.9. Pequeña imagen de la noticia:	29
7.10. Breve resumen de la noticia: (más de 100 palabras)	29
7.11. Relación con la amenaza:	29
7.12. ¿Existe CVE o CWE asociado a la noticia?	30
7.13. Impacto ocasionado por la amenaza en esta noticia: (más de 100 palabras) . . .	30
8. Cross-Site Scripting (XSS)	31
8.1. Breve descripción de la amenaza: (más de 100 palabras)	31
8.2. Fecha de la noticia:	31
8.3. Título de la noticia:	31
8.4. Enlace a la noticia:	32
8.5. Medio:	32
8.6. Enlace al medio:	32
8.7. Nacionalidad del medio:	32
8.8. Idioma de la noticia:	32
8.9. Pequeña imagen de la noticia:	32
8.10. Breve resumen de la noticia: (más de 100 palabras)	33
8.11. Relación con la amenaza:	33
8.12. ¿Existe CVE o CWE asociado a la noticia?	33
8.13. Impacto ocasionado por la amenaza en esta noticia: (más de 100 palabras) . . .	34
9. Conclusiones	35
9.1. Evolución y democratización de las amenazas digitales	35
9.2. Análisis transversal de los vectores de ataque	35

9.2.1. La Inteligencia Artificial como catalizador del engaño	35
9.2.2. El secuestro digital: Del archivo al hardware	36
9.3. La fragilidad del software y la amenaza geopolítica	36
9.4. ¿Qué nos depara el futuro de la ciberseguridad?	37
9.5. Valoración final	37

Capítulo 1

Introducción

1.1. Objetivos de la práctica

El objetivo fundamental de esta práctica es la obtenención de información y familiarización con las amenazas a la seguridad digital.

1.2. Fundamentos teóricos

Para la realización de esta práctica, se aplican diversos conceptos teóricos clave de la ciberseguridad y la seguridad de la información, entre los que destacan:

- **Conocimiento de los CVE/CWE:** CVE (Common Vulnerabilities and Exposures) es un sistema de identificación de vulnerabilidades conocido a nivel mundial, mientras que CWE (Common Weakness Enumeration) clasifica las debilidades de software. Familiarizarse con estas bases de datos es esencial para entender las amenazas actuales y cómo mitigarlas.
- **Phishing:** Técnica de ingeniería social utilizada para engañar a los usuarios y obtener información confidencial, como contraseñas o datos bancarios, a través de correos electrónicos, mensajes o sitios web falsos.
- **Malware:** Software malicioso diseñado para dañar, explotar o comprometer sistemas informáticos. Puede incluir virus, troyanos, ransomware, spyware, entre otros.
- **Ransomware:** Tipo de malware que cifra los archivos de la víctima y exige un rescate para restaurar el acceso a los datos. Es una amenaza creciente para empresas y particulares.

- **Botnets:** Redes de dispositivos comprometidos (ordenadores zombies) controlados por un atacante para realizar actividades maliciosas, como ataques DDoS, envío de spam o minería de criptomonedas.
- **SQL Injection:** Vulnerabilidad que permite a un atacante ejecutar código SQL malicioso en una base de datos a través de una aplicación web, lo que puede resultar en la exposición o manipulación de datos sensibles.
- **Cross-Site Scripting (XSS):** Vulnerabilidad que permite a un atacante inyectar scripts maliciosos en páginas web vistas por otros usuarios, lo que puede llevar al robo de cookies, secuest

1.3. Enunciado de la práctica

Esta práctica consiste en la realización de un informe basado en una selección de noticias de prensa digital, posteriores al 1 de enero de 2025, relacionadas con una serie de amenazas informáticas.

Las amenazas objeto de esta actividad serán:

1. Phishing, estafas a través de la red
2. Malware difundido en redes sociales
3. Ataques de ransomware contra corporaciones y gobiernos
4. Botnets, ordenadores zombies
5. Malware en dispositivos móviles
6. Inyección de código SQL
7. Cross-Site Scripting (XSS)

Capítulo 2

phishing, estafas a través de la red

2.1. Breve descripción de la amenaza: (más de 100 palabras)

Esta amenaza representa una evolución sofisticada del fraude financiero tradicional, combinando el *phishing* clásico con tecnologías de Inteligencia Artificial. El núcleo del engaño reside en el uso de Inteligencia Artificial generativa para la creación de *deepfakes* de alta calidad, permitiendo suplantar la imagen y voz de figuras públicas reconocidas para dotar de una falsa legitimidad a plataformas de inversión fraudulentas. El esquema sigue la metodología conocida como *Pig Butchering* (matanza del cerdo), un proceso de manipulación psicológica a largo plazo donde los atacantes establecen una relación de confianza con la víctima antes de proceder al robo total de sus activos. La amenaza se apoya en algoritmos de segmentación en redes sociales para localizar objetivos vulnerables, empleando además una infraestructura tecnológica compleja que incluye el uso de criptomonedas para dificultar la trazabilidad del dinero y el blanqueo de los capitales obtenidos ilícitamente a través de pasarelas de pago internacionales.

2.2. Fecha de la noticia:

07/04/2025

2.3. Título de la noticia:

Detenidas seis personas por estafar más de 19 millones de euros usando inteligencia artificial

2.4. Enlace a la noticia:

<https://www.interior.gob.es/opencms/es/detalle/articulo/Detenidas-seis-personas-por-estafar-mas-de-19-millones-de-euros-usando-inteligencia-artificial/>

2.5. Medio:

Ministerio del Interior (España)

2.6. Enlace al medio:

<https://www.interior.gob.es/>

2.7. Nacionalidad del medio:

Española

2.8. Idioma de la noticia:

Español

2.9. Pequeña imagen de la noticia:



2.10. Breve resumen de la noticia: (más de 100 palabras)

En una operación conjunta denominada COINBLACK-WENDIMINE, la Policía Nacional y la Guardia Civil han logrado dismantelar una organización criminal internacional responsable de una estafa que asciende a 19 millones de euros, afectando a más de 200 víctimas registradas. El *modus operandi* comenzaba con la difusión de anuncios falsos en redes sociales, donde mediante el uso de IA, se mostraba a famosos recomendando inversiones “altamente rentables” en criptomonedas. Cuando los interesados facilitaban sus datos, eran contactados por supuestos asesores financieros que, mediante técnicas de ingeniería social, les inducían a realizar depósitos crecientes. La parte más interesante era que, una vez que la víctima sospechaba del fraude, los delincuentes volvían a contactarla suplantando la identidad de agentes de Europol o de bufetes de abogados especializados. Bajo esta nueva fachada, prometían recuperar los fondos perdidos a cambio de un pago previo por "tasas de recuperación", logrando así victimizar doblemente a las personas mediante un esquema de estafa por segunda intención.

2.11. Relación con la amenaza:

Se trata de un caso complejo de *phishing* y estafa financiera multietapa. Utiliza ingeniería social avanzada, suplantación de identidad (*spoofing*) mediante IA y manipulación psicológica para el robo de activos financieros.

2.12. ¿Existe CVE o CWE asociado a la noticia?

No se menciona un CVE específico ya que no se basa en una vulnerabilidad de software técnica, sino en ingeniería social. Se podría asociar a **CWE-1031** (Improper Restriction of Generative AI) por el uso de IA generativa para el engaño aunque en mi opinión se presenta complicado restringir la ia para evitar su uso malicioso en este contexto.

2.13. Impacto ocasionado por la amenaza en esta noticia: (más de 100 palabras)

El impacto de esta red criminal es multidimensional y de una gravedad extrema. En el plano puramente económico, la cuantía defraudada supera los 19 millones de euros, pero la devastación financiera personal es aún más alarmante, registrándose casos de víctimas individuales que perdieron hasta 624.000 euros, lo que supone la ruina total de familias y ahorros de toda una vida. Desde el punto de vista legal, la operación ha resultado en la imputación de al menos

208 delitos de estafa, además de cargos por pertenencia a organización criminal y blanqueo de capitales. Existe también un impacto reputacional y técnico significativo, ya que el uso de *deepfakes* erosiona la confianza pública en los canales de información digitales y en las instituciones financieras legítimas. Finalmente, el impacto psicológico en las víctimas es profundo, derivado no solo de la pérdida patrimonial, sino de la manipulación sufrida durante meses y la posterior suplantación de identidad de organismos policiales, lo que genera un sentimiento de desprotección y vulnerabilidad ante las autoridades reales.

Capítulo 3

Malware difundido en redes sociales

3.1. Breve descripción de la amenaza: (más de 100 palabras)

La amenaza central descrita es el uso de malware de tipo *infostealer* (ladrones de información), específicamente familias detectadas en la Operación Secure como Lumma, RisePro, Meta Stealer, Vidar y Rhadamanthys. Estos programas maliciosos están diseñados con el objetivo principal de infiltrarse en dispositivos de víctimas para extraer de forma silenciosa datos extremadamente sensibles. Entre la información comprometida se encuentran credenciales de acceso almacenadas en navegadores, cookies de sesión (que permiten saltarse la autenticación de doble factor), datos de carteras de criptomonedas y detalles financieros. El vector de ataque mencionado incluye técnicas de ingeniería social, campañas de phishing y fraudes en aplicaciones de citas o redes sociales. Una vez que el malware infecta el sistema, recopila la información y la envía a servidores de comando y control (C2). Los datos robados suelen ser vendidos en foros clandestinos de la Dark Web o utilizados directamente por los atacantes para realizar fraudes bancarios, suplantación de identidad o facilitar ataques de ransomware a mayor escala contra infraestructuras corporativas.

3.2. Fecha de la noticia:

14 de junio de 2025

3.3. Título de la noticia:

[Interpol desmantela red global de malware infostealer con 32 detenidos](#)

3.4. Enlace a la noticia:

<https://www.escudodigital.com/ciberseguridad/operacion-secure-infostealer.html>

3.5. Medio:

Escudo Digital

3.6. Enlace al medio:

<https://www.escudodigital.com/>

3.7. Nacionalidad del medio:

España

3.8. Idioma de la noticia:

Español

3.9. Pequeña imagen de la noticia:



3.10. Breve resumen de la noticia: (más de 100 palabras)

Interpol ha liderado una exitosa intervención internacional denominada "Operación Secure", ejecutada durante los primeros cuatro meses de 2025, con el fin de dismantelar una vasta infraestructura de malware *infostealer* en la región de Asia-Pacífico. La operación contó con la colaboración de fuerzas de seguridad de 26 países y empresas de ciberseguridad privadas. Los resultados han sido contundentes: se eliminaron más de 20.000 dominios maliciosos (el 80 % de la infraestructura identificada), se incautaron 41 servidores y se recuperaron más de 100 GB de datos robados. La ofensiva policial culminó con la detención de 32 individuos en Vietnam, Sri Lanka y Nauru, destacando el arresto del presunto cabecilla en Vietnam, a quien se le incautaron dispositivos y dinero en efectivo vinculados a actividades de blanqueo. Las autoridades lograron identificar a más de 216.000 víctimas a nivel global, a quienes se les ha notificado para que tomen medidas preventivas inmediatas, como la revocación de accesos bancarios y el cambio de contraseñas comprometidas, logrando así mitigar un daño masivo a ciudadanos y empresas de múltiples naciones.

3.11. Relación con la amenaza:

La noticia ilustra la lucha global contra la propagación de malware *infostealer*, una amenaza que utiliza las redes sociales y la ingeniería social como principales vectores de difusión para comprometer la seguridad digital de los usuarios.

3.12. ¿Existe CVE o CWE asociado a la noticia?

La noticia no menciona un código CVE específico.

3.13. Impacto ocasionado por la amenaza en esta noticia: (más de 100 palabras)

El impacto de esta red criminal es de escala masiva y multidimensional. A nivel individual, más de 216.000 víctimas sufrieron el robo de su identidad digital, lo que conlleva riesgos de fraude financiero directo, vaciado de cuentas bancarias y pérdida de activos en criptomonedas. En términos técnicos, la infraestructura criminal gestionaba 117 servidores de comando y control distribuidos en 89 proveedores de servicios de Internet distintos, lo que demuestra una capacidad de infección global muy alta. El impacto organizacional es igualmente grave, ya que el robo de cookies de sesión permite a los atacantes evadir sistemas de seguridad corporativos y

penetrar en redes empresariales para realizar espionaje o desplegar ransomware. Además de las pérdidas económicas directas, existe un impacto reputacional y emocional para los afectados. La incautación de 100 GB de datos personales confirma que la escala del espionaje era industrial. Finalmente, la operación resalta la necesidad de cooperación internacional para combatir el impacto transnacional de estas redes, que operan desde múltiples jurisdicciones para dificultar la acción de la justicia.

Capítulo 4

Ataques de ransomware contra corporaciones y gobiernos

4.1. Breve descripción de la amenaza: (más de 100 palabras)

La amenaza descrita consiste en un ataque de ransomware de doble extorsión ejecutado por el grupo criminal “Interlock”. Esta modalidad de ataque no solo se limita al cifrado de archivos críticos para paralizar las operaciones de la entidad víctima (en este caso, un “proveedor” de servicios de diálisis), sino que incluye la exfiltración previa de volúmenes masivos de datos sensibles. El grupo Interlock utilizó técnicas avanzadas para infiltrarse en la red de DaVita, logrando permanecer de forma persistente desde el 24 de marzo hasta el 12 de abril de 2025. Durante este periodo, los atacantes extrajeron aproximadamente 20 terabytes de información, incluyendo bases de datos SQL con más de 200 millones de registros. El ransomware afectó principalmente a los servidores de laboratorio y bases de datos clínicas. Al no concretarse el pago del rescate, los atacantes procedieron a la filtración selectiva de los datos en su sitio de la “Dark Web”, utilizando la exposición de información de salud protegida (PHI) como mecanismo de presión.

4.2. Fecha de la noticia:

22 de agosto de 2025

4.3. Título de la noticia:

[DaVita Confirms 2.7 Million Individuals Affected by Ransomware Attack](#)

4.4. Enlace a la noticia:

<https://www.hipaajournal.com/davita-ransomware-attack/>

4.5. Medio:

The HIPAA Journal

4.6. Enlace al medio:

<https://www.hipaajournal.com/>

4.7. Nacionalidad del medio:

Estados Unidos

4.8. Idioma de la noticia:

Inglés

4.9. Pequeña imagen de la noticia:



The HIPAA Journal is the leading provider of HIPAA training, news, regulatory updates, and independent compliance advice.

Become HIPAA Compliant	HIPAA Checklist	HIPAA News	HIPAA Breach News	Cybersecurity News	HIPAA Legal News	About
Compliance Pros Hub	Small Practices Hub	Business Associate Hub	Health Tech Vendors	HIPAA Training	HIPAA Training Courses	

DaVita Confirms 2.7 Million Individuals Affected by Ransomware Attack

Posted By [Steve Alder](#) on Aug 22, 2025

DaVita, a Denver, CO-based kidney dialysis service provider, has submitted a breach report to the HHS' Office for Civil Rights confirming the number of individuals affected by its April 12, 2025, ransomware attack. Hackers gained access to its network, exfiltrated sensitive data, and then encrypted files on parts of its network. While the attack caused some temporary operational disruption, DaVita said the critical care it provides to patients continued uninterrupted.

DaVita previously confirmed that the ransomware group gained access to a laboratory database containing patient information. The database and other affected parts of the network have been reviewed, and DaVita has now confirmed that the protected health information of 2,689,826 individuals was compromised in the incident. That makes it the third-largest healthcare data breach announced so far this year, behind the cyberattack on [Episource](#) that affected 5.5 million individuals, and the website tracking data breach at [Blue Shield of California](#) that affected 4.7 million individuals.



Get The FREE HIPAA Compliance Checklist

Immediate Delivery of Checklist
Link To Your Email Address

Work Email *

Get Free Checklist

Please Enter Correct Email Address

4.10. Breve resumen de la noticia: (más de 100 palabras)

DaVita, uno de los mayores proveedores de servicios de diálisis en EE. UU., confirmó que un ataque de ransomware ocurrido en abril de 2025 afectó finalmente a 2.689.826 personas. El incidente, atribuido al grupo Interlock, supuso el acceso no autorizado a servidores de red y bases de datos de laboratorio. Aunque la empresa logró mantener la continuidad del tratamiento crítico para sus pacientes, la brecha de seguridad resultó en la exfiltración de 20 TB de datos sensibles, incluyendo nombres, números de Seguro Social, información de seguros médicos y resultados de pruebas de laboratorio. El informe financiero de la compañía reveló que el ataque generó costes de remediación de 13,5 millones de dólares solo en el segundo trimestre de 2025. Tras el fracaso de las negociaciones de rescate, el grupo atacante comenzó a publicar archivos robados en su portal de filtraciones. Como respuesta, DaVita ha comenzado a enviar cartas de notificación a los afectados, ofreciendo servicios de monitoreo de crédito y protección de identidad, mientras enfrenta al menos dos demandas colectivas por presunta negligencia en la custodia de los datos.

4.11. Relación con la amenaza:

La noticia es un ejemplo crítico de ataque de ransomware contra una infraestructura corporativa de salud. Ilustra cómo las corporaciones que manejan datos sensibles son objetivos prioritarios debido al alto valor de la información médica y la presión operativa para restaurar servicios vitales.

4.12. ¿Existe CVE o CWE asociado a la noticia?

La noticia no menciona un código CVE específico.

4.13. Impacto ocasionado por la amenaza en esta noticia: (más de 100 palabras)

El impacto de este ataque es masivo y se divide en tres vertientes: financiera, operativa y legal. Financieramente, DaVita reportó pérdidas directas de 13,5 millones de dólares destinados a especialistas en ciberseguridad, restauración de sistemas y costes administrativos, sin contar las pérdidas potenciales por interrupción de negocio y multas. Operativamente, aunque la atención al paciente no se detuvo, hubo una interrupción significativa en los procesos de laboratorio y administrativos que obligó a implementar procesos manuales temporales. Desde el punto de vista

legal y reputacional, la filtración de datos de 2,7 millones de personas ha derivado en demandas colectivas (como *Reid v. Davita Inc.*) y una investigación de la Oficina de Derechos Civiles (OCR). La exposición de números de Seguro Social y datos clínicos coloca a los pacientes en un riesgo prolongado de robo de identidad y fraude médico, lo que erosiona profundamente la confianza en la institución y requiere inversiones a largo plazo en servicios de protección para los afectados.

Capítulo 5

Botnets, ordenadores zombies

5.1. Breve descripción de la amenaza: (más de 100 palabras)

La amenaza descrita se centra en la proliferación y operación de cuatro grandes botnets de dispositivos infectados: **Aisuru, KimWolf, JackSkid y Mossad**. Estas redes están compuestas por más de tres millones de dispositivos del Internet de las Cosas (IoT), como grabadoras de vídeo digital (DVR), cámaras web y routers WiFi, que han sido transformados en “ordenadores zombies” o nodos de ataque. La peligrosidad de estas botnets radica en su capacidad para lanzar ataques de Denegación de Servicio Distribuido (DDoS) de una magnitud impresionante, alcanzando récords de hasta **30 Terabits por segundo (Tbps)**. Los operadores de estas redes emplean un modelo de “ciberdelincuencia como servicio”, vendiendo el acceso a esta infraestructura a otros delincuentes para saturar servidores y redes, incluyendo activos críticos del Departamento de Defensa de EE. UU. (DoDIN). Estas botnets son particularmente sofisticadas, ya que algunas, como KimWolf y JackSkid, han demostrado capacidad para infectar dispositivos que tradicionalmente se consideran protegidos por firewalls, expandiendo el alcance del secuestro digital a niveles globales.

5.2. Fecha de la noticia:

19 de marzo de 2026

5.3. Título de la noticia:

Authorities disrupt worlds largest IoT DDoS botnets responsible for record breaking attacks targeting victims worldwide

5.4. Enlace a la noticia:

<https://www.justice.gov/usao-ak/pr/authorities-disrupt-worlds-largest-iot-ddos-botnets-responsible-record-breaking-attacks>

5.5. Medio:

U.S. Department of Justice (Oficina del Fiscal de los Estados Unidos, Distrito de Alaska)

5.6. Enlace al medio:

<https://www.justice.gov/>

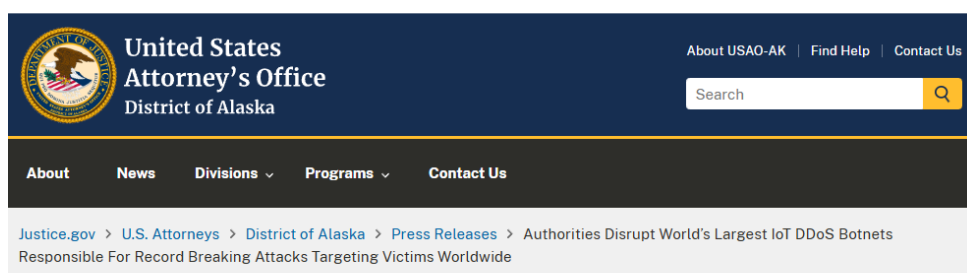
5.7. Nacionalidad del medio:

Estados Unidos (con cooperación de Canadá y Alemania)

5.8. Idioma de la noticia:

Inglés

5.9. Pequeña imagen de la noticia:



PRESS RELEASE

Authorities disrupt world's largest IoT DDoS botnets responsible for record breaking attacks targeting victims worldwide

5.10. Breve resumen de la noticia: (más de 100 palabras)

El Departamento de Justicia de los Estados Unidos, en una operación coordinada con fuerzas de seguridad de Canadá y Alemania, ha desmantelado la infraestructura de Comando y Control (C2) de cuatro de las botnets IoT más potentes del mundo. La intervención incluyó la ejecución de órdenes de incautación de dominios de internet registrados en EE. UU., servidores virtuales y otra infraestructura crítica utilizada para actividades criminales. Estas botnets habían esclavizado más de tres millones de dispositivos en todo el mundo, utilizándolos para ejecutar cientos de miles de ataques DDoS, algunos de los cuales establecieron récords de volumen de tráfico (30 Tbps). La operación no solo se limitó a la infraestructura técnica, sino que también incluyó acciones legales contra los individuos que operaban estas redes en el extranjero. Además de la interrupción técnica, se identificó que los criminales utilizaban estas redes para extorsionar a sus víctimas, exigiendo pagos para detener los ataques. La colaboración de gigantes tecnológicos como Amazon, Google y Cloudflare fue fundamental para identificar y mitigar la conectividad de estas redes "zombie".

5.11. Relación con la amenaza:

La noticia es un ejemplo paradigmático de la amenaza de las botnets, ilustrando cómo dispositivos domésticos e industriales vulnerables son reclutados de forma masiva para formar ejércitos digitales capaces de paralizar infraestructuras nacionales y servicios globales.

5.12. ¿Existe CVE o CWE asociado a la noticia?

La noticia no cita un CVE específico.

5.13. Impacto ocasionado por la amenaza en esta noticia: (más de 100 palabras)

El impacto documentado en esta operación es masivo, tanto a nivel técnico como económico. Financieramente, las víctimas han reportado pérdidas individuales de decenas de miles de dólares derivadas de los gastos de remediación y la interrupción de servicios. A nivel de infraestructura, el impacto es crítico: se lanzaron ataques que superaron los 30 Tbps, una cifra que puede saturar incluso las defensas más robustas de proveedores de servicios de internet y redes gubernamentales. La seguridad nacional también se vio comprometida, ya que las botnets dirigieron ataques específicamente contra la Red de Información del Departamento de Defensa

(DoDIN). Además, el impacto social y de privacidad es notable, dado que más de tres millones de usuarios particulares poseían dispositivos (cámaras, routers) que estaban siendo utilizados para actividades delictivas sin su conocimiento. La escala de la infección subraya una vulnerabilidad sistémica en el ecosistema IoT global, donde la falta de seguridad en dispositivos de consumo se traduce en herramientas de ciberterrorismo y extorsión a gran escala.

Capítulo 6

Malware en dispositivos móviles

6.1. Breve descripción de la amenaza: (más de 100 palabras)

La amenaza descrita se identifica como ****SpyLoan****, un tipo de malware financiero diseñado para dispositivos móviles que opera bajo el esquema de "montadeudas". Este software malicioso se disfraza de aplicaciones legítimas de préstamos rápidos y sin trámites burocráticos, dirigidas principalmente a personas en situación de vulnerabilidad financiera. Una vez instalada, la aplicación solicita permisos excesivos y críticos, como acceso a la lista de contactos, galería de fotos, ubicación GPS y funciones de administración del sistema. El objetivo es doble: por un lado, exfiltran información personal sensible para realizar extorsiones y acoso a los contactos del usuario; por otro lado, el malware tiene la capacidad técnica de bloquear remotamente el acceso al dispositivo móvil del usuario si este no cumple con el pago de intereses abusivos. Esta técnica de "secuestro de hardware" convierte al teléfono inteligente en una garantía forzosa, utilizando el control total sobre el sistema operativo para coaccionar a la víctima, lo que representa una evolución agresiva del ransomware tradicional adaptado al ecosistema móvil.

6.2. Fecha de la noticia:

3 de diciembre de 2025

6.3. Título de la noticia:

Estafa que usa celular como garantía de préstamo se expande por América Latina

<https://latam.kaspersky.com/about/press-releases/estafa-que-usa-celular-como-garantia-de-prestamo-se-expande-por-america-latina>

6.4. Enlace a la noticia:

<https://latam.kaspersky.com/about/press-releases/estafa-que-usa-celular-como-garantia-de-prestamo-se-expande-por-america-latina>

6.5. Medio:

Kaspersky (Sala de Prensa Latam)

6.6. Enlace al medio:

<https://latam.kaspersky.com/>

6.7. Nacionalidad del medio:

Internacional (Reporte específico para América Latina)

6.8. Idioma de la noticia:

Español

6.9. Pequeña imagen de la noticia:



6.10. Breve resumen de la noticia: (más de 100 palabras)

Un informe de Kaspersky revela una expansión masiva de las aplicaciones maliciosas Spy-Loan en América Latina, registrando más de 521,000 bloqueos entre agosto de 2024 y julio de 2025. México lidera el ranking de afectados con 363,000 casos, seguido por Brasil y Colombia. Estas aplicaciones atraen a las víctimas mediante anuncios en redes sociales prometiendo crédito fácil. Una vez descargadas, roban datos personales y bloquean los dispositivos como método de extorsión ante el impago de deudas con intereses usurarios. El reporte advierte además sobre la aparición de un "mercado paralelo" de supuestos hackers que ofrecen servicios para desbloquear estos terminales, lo que supone un riesgo adicional de infección por malware más agresivo. Expertos de la firma de seguridad recalcan que muchas de estas apps logran burlar los filtros de las tiendas oficiales, por lo que recomiendan limitar estrictamente los permisos de las aplicaciones, mantener el sistema operativo actualizado y desconfiar de ofertas financieras que no provengan de instituciones legales reguladas.

6.11. Relación con la amenaza:

La noticia ilustra la convergencia entre el malware móvil y la ingeniería social criminal. Spy-Loan utiliza funciones de administración de dispositivos móviles (MDM) de forma maliciosa para restringir el uso del terminal, convirtiéndolo en un "zombie" bajo control del extorsionador.

6.12. ¿Existe CVE o CWE asociado a la noticia?

Aunque no se cita un CVE por ser un conjunto de apps, se asocia a:

- **CWE-267:** Privilegios Privilegiados (Abuso de permisos administrativos).
- **CWE-281:** Gestión de permisos inadecuada (el usuario otorga acceso total por engaño).
- **CWE-812:** Instalación de software no confiable.

6.13. Impacto ocasionado por la amenaza en esta noticia: (más de 100 palabras)

El impacto de SpyLoan es devastador tanto en el ámbito económico como en el personal. Financieramente, las víctimas se ven atrapadas en un ciclo de deuda impagable debido a intereses que superan la legalidad, sumado al costo de intentar recuperar el acceso a sus dispositivos. A

nivel de privacidad, la filtración de listas de contactos permite a los criminales extender el acoso a familiares y amigos de la víctima, dañando su reputación y círculo social. El impacto técnico es crítico, ya que el bloqueo del dispositivo inutiliza una herramienta esencial para el trabajo y la comunicación. Además, el surgimiento de servicios fraudulentos de desbloqueo agrava la situación, pues los usuarios, en su desesperación, instalan más software malicioso que puede resultar en el robo total de cuentas bancarias y credenciales. Este fenómeno genera una desconfianza sistémica en las aplicaciones de tecnología financiera (Fintech) y resalta la vulnerabilidad de más de medio millón de usuarios en la región.

Capítulo 7

Inyección de código SQL

7.1. Breve descripción de la amenaza: (más de 100 palabras)

La amenaza descrita se centra en una vulnerabilidad de inyección SQL de día cero (zero-day) identificada como CVE-2025-1094, localizada en las funciones de la biblioteca *libpq* de PostgreSQL. Este fallo técnico surge debido a una neutralización inadecuada de la sintaxis de escape en funciones críticas como *PQescapeLiteral()* y *PQescapeString()*. Específicamente, el problema reside en cómo el terminal interactivo de PostgreSQL (*psql*) procesa secuencias de bytes no válidas provenientes de caracteres UTF-8 mal formados. Los atacantes pueden aprovechar este error para manipular consultas SQL y ejecutar comandos arbitrarios en la base de datos cuando la aplicación utiliza estos resultados para construir entradas. En el contexto del ataque a la empresa BeyondTrust, esta vulnerabilidad fue encadenada con otros fallos de inyección de argumentos para lograr la ejecución remota de código (RCE). Lo que hace a esta amenaza particularmente peligrosa es su capacidad de evadir mecanismos de seguridad estándar mediante el uso de codificaciones de caracteres específicas (como BIG5 o EUC_TW), permitiendo a actores estatales realizar espionaje y robo de datos a gran escala.

7.2. Fecha de la noticia:

14 de febrero de 2025

7.3. Título de la noticia:

PostgreSQL flaw exploited as zero-day in BeyondTrust breach

<https://www.bleepingcomputer.com/news/security/postgresql-flaw-exploited-as-zero-day-in-beyondtrust-breach/>

7.4. Enlace a la noticia:

<https://www.bleepingcomputer.com/news/security/postgresql-flaw-exploited-as-zero-day-in-beyondtrust-breach/>

7.5. Medio:

BleepingComputer

7.6. Enlace al medio:

<https://www.bleepingcomputer.com/>

7.7. Nacionalidad del medio:

Estados Unidos

7.8. Idioma de la noticia:

Inglés

7.9. Pequeña imagen de la noticia:



7.10. Breve resumen de la noticia: (más de 100 palabras)

La empresa de ciberseguridad Rapid7 reveló que un grupo de hackers vinculados al estado chino, conocido como "Silk Typhoon", explotó una vulnerabilidad de día cero en PostgreSQL para infiltrarse en la red de BeyondTrust y en 17 de sus instancias SaaS de Soporte Remoto. El ataque, ocurrido inicialmente en diciembre, permitió a los atacantes comprometer posteriormente la red del Departamento del Tesoro de los Estados Unidos utilizando claves de API robadas. Según la investigación, el fallo CVE-2025-1094 facilitó inyecciones SQL mediante el procesamiento incorrecto de caracteres UTF-8 inválidos, lo cual fue fundamental para que los atacantes logaran la ejecución de código. Los objetivos principales fueron organismos críticos como el Comité de Inversión Extranjera (CFIUS) y la Oficina de Control de Activos Extranjeros (OFAC). Aunque BeyondTrust lanzó parches de seguridad, la noticia destaca la sofisticación de los atacantes para encadenar múltiples vulnerabilidades (CVE-2024-12356 y CVE-2025-1094) con el fin de extraer información clasificada sobre sanciones económicas y documentos de seguridad nacional antes de que el fallo fuera hecho público.

7.11. Relación con la amenaza:

La noticia ilustra un caso avanzado de inyección SQL donde la vulnerabilidad no reside en el código de la aplicación final, sino en las funciones de escape de la base de datos PostgreSQL. Demuestra cómo una inyección SQL puede ser el catalizador para un compromiso total del sistema (RCE) en infraestructuras críticas de software de acceso privilegiado.

7.12. ¿Existe CVE o CWE asociado a la noticia?

Sí, la noticia menciona explícitamente:

- **CVE-2025-1094:** Vulnerabilidad de inyección SQL en PostgreSQL.
- **CWE-89:** Inyección SQL (Improper Neutralization of Special Elements used in an SQL Command).
- **CWE-88:** Inyección de argumentos (mencionado por Rapid7 como reclasificación de CVE-2024-12356).

7.13. Impacto ocasionado por la amenaza en esta noticia: (más de 100 palabras)

El impacto de este ataque es de carácter geopolítico y sistémico. A nivel corporativo, BeyondTrust sufrió una brecha en su infraestructura principal y en múltiples instancias de clientes SaaS, afectando su reputación como proveedor de gestión de accesos privilegiados. Sin embargo, el impacto más grave se trasladó al sector público, donde el Departamento del Tesoro de EE. UU. vio comprometida su red. El grupo Silk Typhoon logró acceder a información sensible relativa a sanciones internacionales y documentos de seguridad nacional de oficinas clave como la OFAC y el CFIUS. Este incidente forzó a la agencia CISA a emitir mandatos de parcheo urgente para todas las agencias federales en plazos de menos de una semana. En términos técnicos, el ataque demostró que incluso las bibliotecas de bases de datos maduras como PostgreSQL pueden ocultar fallos de día cero que permiten el movimiento lateral y la exfiltración masiva de datos no clasificados pero críticos para la política exterior de una potencia mundial, subrayando la fragilidad de las cadenas de suministro de software gubernamental.

Capítulo 8

Cross-Site Scripting (XSS)

8.1. Breve descripción de la amenaza: (más de 100 palabras)

La amenaza descrita se basa en una vulnerabilidad de tipo XSS persistente o almacenado (Stored Cross-Site Scripting), identificada técnicamente como CVE-2025-66376, que afecta a la plataforma de colaboración Zimbra (ZCS). En este tipo de ataque, el actor de la amenaza, en este caso el grupo estatal ruso APT28, inyecta un script malicioso (payload) directamente en el cuerpo HTML de un correo electrónico. A diferencia del XSS reflejado, el código malicioso queda almacenado en el servidor de correo. Cuando un usuario autenticado abre el mensaje en su cliente de webmail, el navegador ejecuta automáticamente el JavaScript malicioso de forma silenciosa. Este script tiene la capacidad de secuestrar la sesión del usuario, acceder al Document Object Model (DOM) de la página y, en última instancia, permitir a un atacante no autenticado lograr la ejecución remota de código (RCE). Al ejecutarse en el contexto de una sesión legítima, el malware puede evadir controles de seguridad tradicionales y realizar acciones en nombre del usuario, como el robo de tokens de acceso y la exfiltración de datos privados.

8.2. Fecha de la noticia:

19 de marzo de 2026

8.3. Título de la noticia:

Russian hackers exploit Zimbra flaw in Ukrainian govt attacks

<https://www.bleepingcomputer.com/news/security/russian-apt28-military-hackers-exploit-zimbra-flaw-in-ukrainian-govt-attacks/>

8.4. Enlace a la noticia:

<https://www.bleepingcomputer.com/news/security/russian-apt28-military-hackers-exploit-zimbra-flaw-in-ukrainian-govt-attacks/>

8.5. Medio:

BleepingComputer

8.6. Enlace al medio:

<https://www.bleepingcomputer.com/>

8.7. Nacionalidad del medio:

Estados Unidos

8.8. Idioma de la noticia:

Inglés

8.9. Pequeña imagen de la noticia:



8.10. Breve resumen de la noticia: (más de 100 palabras)

El grupo de hacking APT28, vinculado a la inteligencia militar rusa (GRU), está explotando activamente una vulnerabilidad XSS de alta severidad en Zimbra para atacar entidades gubernamentales en Ucrania. Según investigadores de Seqrite Labs, la campaña denominada .Operation GhostMail utiliza correos electrónicos de phishing que no contienen archivos adjuntos ni enlaces sospechosos; en su lugar, el ataque reside enteramente en el cuerpo HTML del mensaje. Una vez que el objetivo abre el correo en su sesión de Zimbra, un script de JavaScript ofuscado se ejecuta para recolectar credenciales, tokens de sesión, códigos de respaldo de autenticación de dos factores (2FA) y contraseñas guardadas en el navegador. Además, el malware es capaz de exfiltrar el contenido de los buzones de correo de los últimos 90 días utilizando protocolos DNS e HTTPS. La gravedad del incidente ha llevado a la agencia CISA a incluir esta vulnerabilidad en su catálogo de fallos explotados activamente, ordenando a las agencias federales de EE. UU. securizar sus servidores para evitar compromisos similares.

8.11. Relación con la amenaza:

La noticia demuestra el uso avanzado de XSS almacenado como vector de entrada inicial en operaciones de ciberespionaje. El fallo permite convertir un simple visualizador de correos en una herramienta de ejecución de código, saltándose las defensas convencionales contra malware basado en archivos.

8.12. ¿Existe CVE o CWE asociado a la noticia?

Sí, la noticia identifica específicamente:

- **CVE-2025-66376**: El identificador de la vulnerabilidad en Zimbra Collaboration Suite.
- **CWE-79**: Neutralización inadecuada de la entrada durante la generación de páginas web (Cross-Site Scripting).
- **CWE-80**: XSS donde el script se almacena en el servidor.

8.13. Impacto ocasionado por la amenaza en esta noticia: (más de 100 palabras)

El impacto de esta amenaza es crítico, afectando directamente a la seguridad nacional de Ucrania y a la integridad de sus infraestructuras esenciales, como la Agencia Estatal de Hidrología. Al comprometer los servidores de Zimbra, los atacantes obtienen acceso total a las comunicaciones diplomáticas, militares y administrativas, permitiendo el robo de información estratégica y de inteligencia. La exfiltración de datos recolectados, que incluye correos de hasta tres meses de antigüedad y códigos 2FA, otorga a APT28 la capacidad de realizar persistencia a largo plazo en las redes gubernamentales. Además, el impacto se extiende globalmente debido a la popularidad de Zimbra, lo que pone en riesgo a miles de empresas y organismos internacionales que utilizan esta suite. La necesidad de respuesta rápida, evidenciada por el mandato de CISA, subraya un impacto operativo significativo, obligando a administradores de todo el mundo a realizar auditorías urgentes y aplicar parches para prevenir el espionaje masivo y la pérdida de soberanía digital.

Capítulo 9

Conclusiones

9.1. Evolución y democratización de las amenazas digitales

Tras analizar detalladamente los diversos casos de estudio presentados a lo largo de este informe, resulta evidente que el panorama de la ciberseguridad ha experimentado una transformación drástica en los últimos años. Las amenazas han dejado de ser incidentes aislados protagonizados por atacantes solitarios para convertirse en operaciones a escala industrial, orquestadas por verdaderos sindicatos del crimen organizado y actores patrocinados por Estados. La convergencia de tecnologías emergentes, como la Inteligencia Artificial, con vectores de ataque clásicos ha provocado que la complejidad estructural de los incidentes escale de manera exponencial.

El modelo de "Cibercrimen como Servicio" (CaaS) ha democratizado el acceso a herramientas destructivas. Operaciones como las gigantescas botnets del Internet de las Cosas (capaces de generar tráfico DDoS de hasta 30 Tbps) demuestran que ya no es necesario poseer altos conocimientos técnicos para paralizar las infraestructuras de un país; basta con tener los recursos financieros para alquilar estos servicios en foros clandestinos.

9.2. Análisis transversal de los vectores de ataque

9.2.1. La Inteligencia Artificial como catalizador del engaño

Uno de los descubrimientos más alarmantes en el estudio del phishing moderno es la integración profunda de la IA generativa. El caso en el que se defraudaron más de 19 millones de euros utilizando *deepfakes* demuestra que el clásico correo mal redactado ha quedado en el pasado. Los atacantes ahora son capaces de crear campañas a largo plazo (como la estafa *Pig Butchering*), donde suplantán a figuras públicas con un nivel de realismo que resulta indistingui-

ble para el ciudadano medio. Esto nos lleva a concluir que las defensas puramente tecnológicas son insuficientes; es necesaria una reeducación masiva de la sociedad para fomentar un escepticismo digital crítico frente a la hiperrealidad de los contenidos en la red.

9.2.2. El secuestro digital: Del archivo al hardware

La evolución del software malicioso ha ramificado sus estrategias de monetización. Por un lado, tenemos el impacto tradicional y devastador del ransomware en grandes corporaciones, evidenciado en el ataque a DaVita. Este incidente confirma que los sectores críticos (como el sanitario) son presas favoritas por su baja tolerancia a la inactividad operativa y la sensibilidad de sus datos (PHI), lo que empuja a la doble extorsión.

Por otro lado, se ha observado una mutación espeluznante en el entorno móvil con amenazas como SpyLoan. Aquí, el ransomware se transforma en un "secuestro de hardware" disfrazado de solución financiera. El atacante ya no cifra los archivos, sino que bloquea completamente el terminal, utilizando simultáneamente los datos personales para coaccionar y humillar a la víctima en su entorno social. Este enfoque pone de manifiesto que las vulnerabilidades socioeconómicas están siendo explotadas directamente mediante la tecnología.

9.3. La fragilidad del software y la amenaza geopolítica

El estudio de las inyecciones SQL y el Cross-Site Scripting (XSS) en este informe revela una tendencia crítica: el ecosistema del software actual, incluso aquel considerado maduro y ampliamente confiable (como PostgreSQL o Zimbra), oculta debilidades que son aprovechadas activamente en conflictos geopolíticos.

El ciberespionaje ha encontrado en estas vulnerabilidades su mejor aliado. Casos como el del grupo "Silk Typhoon" atacando al Departamento del Tesoro de EE. UU. a través de un *zero-day* en una librería de bases de datos, o el grupo APT28 inyectando *payloads* silenciosos en correos electrónicos de instituciones ucranianas, demuestran que ninguna capa del software está a salvo. Una inyección SQL no neutralizada ya no solo pone en riesgo una base de datos local, sino que compromete la seguridad nacional de potencias mundiales mediante la ejecución remota de código (RCE). Esto subraya la urgencia de establecer auditorías de código abierto mucho más rigurosas y la adopción universal de arquitecturas de Confianza Cero (Zero Trust).

9.4. ¿Qué nos depara el futuro de la ciberseguridad?

A partir de la redacción de este documento, podemos extraer varias lecciones y previsiones para el futuro a corto y medio plazo en el sector de la Seguridad de la Información:

1. **La omnipresencia del IoT como arma de doble filo:** Mientras los fabricantes prioricen el coste y la facilidad de uso sobre la seguridad desde el diseño ("Security by Design"), de dispositivos domésticos seguirán siendo asimilados en botnets globales. Se requerirá legislación internacional estricta que prohíba contraseñas por defecto y obligue a un ciclo de vida de parches.
2. **Colaboración policial internacional:** Casos de éxito como la "Operación Secure" de Interpol confirman que la única forma de dismantelar complejas infraestructuras de *infos-tealers* (que facilitan intrusiones mayores) es la cooperación transfronteriza y la colaboración directa con empresas privadas de ciberseguridad.
3. **La IA defensiva como respuesta imperativa:** Del mismo modo que los atacantes usan IA para automatizar campañas e inyectar código polimórfico, los equipos del *Blue Team* deben delegar sus operaciones de detección de intrusos (IDS), análisis heurístico y triaje de incidentes a inteligencias artificiales capaces de operar a la velocidad de la máquina, neutralizando, por ejemplo, los *deepfakes* antes de que lleguen a los clientes de correo.

9.5. Valoración final

En conclusión, la práctica 8 ha puesto de relieve que la seguridad digital ya no puede ser tratada como un departamento aislado y puramente técnico dentro de las organizaciones, ni como un aspecto secundario en la vida diaria de las personas. La interconexión total del mundo moderno ha provocado que cualquier vulnerabilidad técnica (CWE) escale rápidamente hacia un ataque crítico que impacta la economía de familias, paraliza hospitales y vulnera la soberanía de los Estados.

Para poder hacer frente a las ciberamenazas de esta década y más allá, es imprescindible adoptar un enfoque holístico que integre el desarrollo seguro de software y unos mecanismos de parcheo veloces e inmediatos. Solo mediante la sinergia entre tecnología, educación, leyes robustas e inversión proactiva podremos construir un ciberespacio más resiliente.